

Scheduled Maintenance: On Tuesday, 16 April, IEEE Xplore will undergo scheduled maintenance from 1:00-5:00 PM ET (1700-2100 UTC). During this time, there may be intermittent impact on performance. We apologize for any inconvenience.

[IEEE.org](#)[IEEE Xplore](#)[IEEE SA](#)[IEEE Spectrum](#)[More Sites](#)[Subscribe](#)[Donate](#)[Cart](#)[Welcome Pawan Shah](#)[Sign Out](#)[Browse](#)[My Settings](#)[Help](#)[Institutional Sign In](#)[Institutional Sign In](#)

All



ADVANCED SEARCH

[Journals & Magazines](#) > [IEEE Access](#) > [Volume: 10](#)

A Survey on the Cyber Security of Small-to-Medium Businesses: Challenges, Research Focus and Recommendations

Publisher: IEEE

[Cite This](#)[PDF](#)

<< Results

[Alladean Chidukwani](#) ; [Sebastian Zander](#) ; [Polychronis Koutsakis](#)[All Authors](#)17
Cites in
Papers11046
Full
Text Views

Alerts

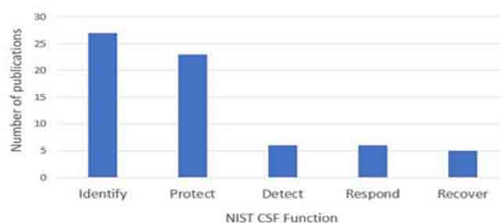
[Manage Content Alerts](#)
[Add to Citation Alerts](#)[Open Access](#) [Comment\(s\)](#)

Under a Creative Commons License

Abstract

Document Sections

- I. Introduction
- II. Cyber Security Situation for SMBS
- III. Cyber Security Frameworks
- IV. Related Surveys
- V. Paper Selection Criteria

[Show Full Outline](#)[Authors](#)[Figures](#)[References](#)[Citations](#)

NIST CSF Functions - focus of SMB cyber security research. This figure shows that the Identify and Protect functions of NIST CSF have been the focus of most previous and ... [View more](#)

Abstract: Small-to-medium sized businesses (SMBs) constitute a large fraction of many countries' economies but according to the literature SMBs are not adequately implementing cyber... [View more](#)

► Metadata

Abstract:

Small-to-medium sized businesses (SMBs) constitute a large fraction of many countries' economies but according to the literature SMBs are not adequately implementing cyber security which leaves them susceptible to cyber-attacks. Furthermore, research in cyber security is rarely focused on SMBs, despite them representing a large proportion of

PDF

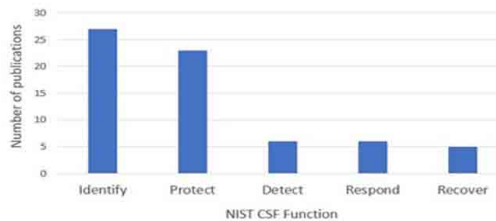
[Help](#)

Keywords

Metrics

More Like This

businesses. In this paper we review recent research on the cyber security of SMBs, with a focus on the alignment of this research to the popular NIST Cyber Security Framework (CSF). From the literature we also summarise the key challenges SMBs face in implementing good cyber security and conclude with key recommendations on how to implement good cyber security. We find that research in SMB cyber security is mainly qualitative analysis and narrowly focused on the Identify and Protect functions of the NIST CSF with very little work on the other existing functions. SMBs should have the ability to detect, respond and recover from cyber-attacks, and if research lacks in those areas, then SMBs may have little guidance on how to act. Future research in SMB cyber security should be more balanced and researchers should adopt well-established powerful quantitative research approaches to refine and test research whilst governments and academia are urged to invest in incentivising researchers to expand their research focus.



NIST CSF Functions - focus of SMB cyber security research. This figure shows that the Identify and Protect functions of NIST CSF have been the focus of most previous and ... [View more](#)

Published in: IEEE Access (Volume: 10)

Page(s): 85701 - 85719

DOI: 10.1109/ACCESS.2022.3197899

Date of Publication: 10 August 2022 ?

Publisher: IEEE

Electronic ISSN: 2169-3536

► **Funding Agency:**

CCBY - IEEE is not the copyright holder of this material. Please follow the instructions via <https://creativecommons.org/licenses/by/4.0/> to obtain full-text articles and stipulations in the API documentation.

SECTION I. Introduction

On the global level, SMBs are responsible for more than 90 percent of the worldwide business economy [1]. In Australia in particular, SMBs make up 98% of all Australian businesses, producing one-third of the total GDP and employing 4.7 million people [2] whilst in the UK, SMBs make up 99.9% of all businesses [3]. Since there are varying definitions of SMBs or small-to-medium enterprises (SMEs) [4], [5], we are using the definition of the Australian Bureau of Statistics defining SMBs as businesses employing between 5 – 199 staff [6].

Based on the major role that SMBs play in the economy, it would be expected that they would adequately implement cyber security strategies. However this is not the case as explained in [7], and this makes them susceptible to financial, productivity and legal costs that can even lead to bankruptcy.

Attackers have now turned to the easy target of SMBs many of which are either unaware [8] or not well resourced to fortify their networks and information resources [9]. Despite there being well known measures to protect businesses from cyber-attacks, SMBs continue to be victims [10]. Statistics show that 62% of Australian SMBs reported to have been a victim of cyber-attacks [11].

PDF

Help

This statistic is closely aligned with the 2017 global statistic where 66% of SMBs reported their organization experiencing a cyberattack in the previous 12 months. These statistics are not only a concern for SMBs but also a concern for suppliers and customers who do business with them [12].

Cyber security is defined as “the art of protecting networks, devices, and data from unauthorised access or criminal use and the practice of ensuring confidentiality, integrity, and availability of information” [13]. Cyber security research is a growing field with numerous topics which authors such as Suryotrisongko and Musashi have tried to develop taxonomies for [14]. Our study was necessitated by the realisation that there was very limited literature available regarding the cyber security of SMBs – both in Australia and globally [15]. To the best of our knowledge, only two surveys of a similar nature have been done [15], [16] which we discuss in more detail in Section IV. None of the existing surveys aligned their surveyed research to a well-known security framework or analysed the geographic spread of the surveyed research.

This motivated our study on the available literature and its focus as well as areas of SMB research that are underrepresented. From our experience and assertions from others [17], the practical and cohesive application of cyber security practices in industry is accomplished through the adoption of cyber security frameworks which provide structure and methodology [18]. Many frameworks exist, among which the National Institute of Standards and Technology Cyber Security Framework (NIST CSF) is popular amongst SMBs. Using the NIST CSF as a benchmark, the aim of our research is to understand the focus of previous SMB cyber security research and identify areas that may be lacking. The secondary aim is to establish in which countries or regions SMB cyber security research is being conducted, what research methodologies are being used and which data gathering techniques are being employed. Another aim was to analyse what researchers identified as the challenges faced by SMBs and what the recommended cyber security practices are.

Our study asked the following questions:

1. What has been the focus of SMB cyber security research?
2. How does past and current SMB cyber security research align with the widely used NIST CSF?
3. What areas of SMB cyber security research need more focus?
4. What is the most common SMB cyber security research methodology?
5. What data gathering techniques are SMB cyber security researchers using?
6. What is the geographic spread of SMB cyber security research?
7. What are the common challenges affecting SMB implementation of good cyber security?
8. What are the recommended cyber security practices for SMBs?

Compared to [15], [16] our work discusses a much larger body of relevant literature and categorizes the literature using a taxonomy based on NIST CSF. Hence, our survey covers more depth and breadth than existing work.

We anticipate that the results of this study will be useful to SMB cyber security researchers, academic institutions, research institutions, governments, and policy makers. Researchers can adopt a more targeted approach to their SMB cyber security research by focussing more on the underrepresented research areas. Academic/research institutions and governments could also incentivise researchers to carry out research in the lacking areas to ensure a well-balanced approach and ultimately help secure SMBs and subsequently the economies.

In section II to set the scene we discuss the difference between SMBs and larger organisations, current cyber-attacks and their cost to SMBs. In section III we briefly discuss cyber security frameworks and standards applicable to SMBs with a focus on the NIST framework which we use to classify the existing literature. In section IV we discuss the few existing surveys in this area. In section V we explain the paper selection criteria for the survey. In section VI we present our survey in two parts. Firstly, we discuss the challenges identified in previous literature and secondly, we



Download
PDF



Contents



PDF

Help

discuss the literature through the lens of the NIST framework. In section VII we discuss the findings and summarize the recommendations for a good cyber security posture of SMBs. Section VIII presents the conclusions of this work.



Download
PDF



Contents



SECTION II.

Cyber Security Situation for SMBS

In this section we discuss the differences between SMBs and large organisations when it comes the cyber security situation. We continue to discuss current cyber-attacks against SMBs and their cost implications.

A. SMBS Vs. Large Enterprises

Cyber threats do not discriminate by organisation size, which means SMBs are susceptible to the same threats as large organisations [19]. Although larger enterprises have a larger attack surface with more employees and devices, larger organisations also, in most cases, have the human and financial resources to put in place controls [9], [20]. Larger organisations tend to have dedicated cyber security staff with appropriate levels of education [21]. SMBs invest less in cyber security [20], however when it comes to the financial impact of successful cyber-attacks, they suffer higher costs proportionately than large businesses [10], [22]. SMBs however have the potential advantage of being small and agile with more flexible IT arrangements [23].

Industry research revealed that although cyber risk became more firmly entrenched in larger organisations' priorities in the past few years, the confidence of many organisations in their ability to manage cyber risk had declined as they were found to still struggle to articulate, approach and act upon cyber risk despite having the relevant human and financial resources [24]. They were also found struggling to educate and train their employees on cyber security [25], a challenge also common in SMBs.

Williams and Manheke [26] argued that cyber security threats to small business should be treated as a matter of national security. They argued that in a country like Australia where much of the business and economy lies in the hands of small businesses, the financial well-being of large groups of society could be affected by cyber-attacks on the business sector impinging on the confidence on e-commerce and the economy as a whole.

B. SMBS Under Attack

Hayes and Bodhani [27] found that SMBs are being increasingly targeted by online threats because they are perceived as being inherently more vulnerable. New and less experienced cyber criminals often attack easy targets among which SMBs are featured [28]. The authors attribute this lax security to SMBs planning their IT security under the misconception that their networks and data are already safe.

A 2020 report from Verizon indicated that the attacks are far reaching with every organisation no matter the size, industry or sector, falling victim [19]. It is noted however that globally, health care service providers and finance related businesses are the most targeted [29], [30]. Academia and industry reports reveal that the most common cyber-attack types experienced by SMBs included: social engineering (e.g., phishing), hacking (e.g., stolen credentials, data theft), malware (e.g., ransomware), misuse (e.g., malicious insider), web-based attacks and ecommerce supply chain attacks [19], [31], [32], [33], [34]. Fig. 1 below shows the results from the Ponemon Institute's 2018 study showing phishing or social engineering attacks as the most prominent types of attack experienced by SMB respondents [31].



FIGURE 1.

Types of attack experienced by SMBs from [31]. Social engineering is the most prominent attack and increasing from previous years.

PDF

Help



Globally and across all organisations, web application servers appear to be the most targeted IT assets in data breaches largely due to the shift towards web-based applications due to an increasing consumption of services offering cloud-based software-as-a-service platforms. Other assets under attack are users' desktops and laptops, email servers, database servers and the end-users themselves [19]. Some researchers believe that mobile devices [35] and other IoT devices are the most vulnerable devices in the SMB environment which are most likely to be compromised and allow attackers entry into the network [8], [36], [37].

Unsecured online devices can also be weaponised to carry out sophisticated attacks on other organisations. For example, devices can be coerced into Botnets, awaiting instructions to join online distributed denial of service (DDoS) attacks [38].

As reported in [22], 70% of recent global breaches were perpetrated mainly by external actors, i.e., attackers from outside the company. Almost half of these attacks involved intrusion or gaining unauthorised access. The vast majority (86%) of these breaches were financially motivated, however cyber incidents and data breaches have several other motivators which include fun, ideology, grudges, espionage, state sponsored and human error [19].

Although most cyber-attacks were from external actors, in 2018, 16% of SMBs reported suffering an insider attack [31]. Williams and Manheke argued that human error both intentional and unintentional has a great impact on SMBs given that it affects many areas of protecting computer systems [26]. For example, in 2011 the Maricopa County Community College District (MCCCD) suffered a data breach with some of the college's databases being posted for sale on the dark web. Investigations revealed the issue was caused by an employee but did not reveal whether the data was intentionally or accidentally leaked [39]. In Australia, 11% of data breaches reported to the Office of The Australian Information Commissioner (OAIC) were the result of a rogue employee or insider attack [29].

C. Cost of Poor Cyber Security for SMBS

Cyber-attacks are becoming more severe in terms of negative consequences such as financial impacts [40]. According to the Australian Criminal Intelligence Commission (ACIC), cybercrime is costing the Australian economy up to \$ 1 billion annually in direct costs alone. The impact of cybercrime can be far reaching with other indirect costs coming in the form of damage to personal identity, loss of business or employment opportunities and significant impact on emotional and psychological wellbeing [41]. It is reported that about 60% of small businesses that were victims of a cyberattacks went out of business within six months [42]. This demonstrates that small businesses have a lot to lose if cyber threats materialise and it is in their best interest to have cyber defences in place.

Lost business was one of the largest costs for small business, along with financial loss, lawsuits, victim compensation, fines and internal investigations [30]. Once a data breach has occurred, the cost of compliance activities, training, research and upgrades to infrastructure could be significant [43]. In addition, businesses are susceptible to repeat attacks given hackers are likely to return. Research highlights that 28% of non-compliant victims are likely to suffer another breach within two years after the initial attack [44].

In the case of the payment and card industry, non-compliance with the Payment Card Industry Data Security Standard (PCI DSS) could lead to the business not being able to accept credit card payments for the goods sold or services rendered [45]. Other risks of fallout from not being compliant can be reputational. SMBs suffer a disproportionately higher financial impact from cyber-attacks when their losses are adjusted to organizational size and revenue [22]. As of 2019, smaller organisations were found to have higher costs relative to their size than larger organisations, incurring an average cost of USD \$ 3533 per employee, compared to USD \$ 204 per employee for larger organisations [10]. The average cost of a data breach in Australia is \$ 2.13 million while companies spend an average of \$ 1.2 million due to damage or theft of IT assets and infrastructure. Additionally, disruption to normal operations cost an average of \$ 1.9 million and these figures continue to increase from previous years [10], [31], [46].

Lloyd [47] claims that effective cyber security allows a business to demonstrate a high level of corporate social responsibility, showing customers commitment to security and privacy which leads to customer retention. Conversely it can be argued that ineffective cyber security demonstrates a lack of corporate social responsibility and disregard for customer security and privacy, leading to loss of customers.

Given many damaging data breaches are not reported, large organisations are now scrutinising the security practices of potential SMB third parties or suppliers to ensure a secure end-to-end supply chain can be achieved [12]. The US retailer Target suffered a large data breach in 2013 after hackers exploited the network access of a small heating, ventilation, and air-conditioning system supplier [48].

The existence of good cyber security practices in an SMB creates a competitive advantage for them in the market. It creates opportunities for lucrative supply chain contracts for which SMBs would not otherwise be a contender without good cyber security. A good example is the stringent cyber security compliance requirement that the US Department of Defence now imposes on defence contractors which is likely to preclude a lot of SMBs from bidding for defence contracts [49]. Effectively, SMBs who fail to invest in data security and governance miss out on market opportunities. When cyber security is not a priority it can become a growth inhibitor for an SMB.

SECTION III.

Cyber Security Frameworks

Cyber security frameworks define best practices that SMBs can follow to manage cyber security risk, establish a common language internally and externally, standardise service delivery and improve efficiency [50]. As pointed out by previous researchers, SMBs should adopt these frameworks to guide their cyber security implementations [15], [28].

A. NIST Cyber Security Framework

The taxonomy we use to classify the literature is based on the National Institute of Standards and Technology (NIST) Cyber Security Framework (CSF) which was developed to help improve the security of critical infrastructure organisations in the USA [51]. It is a voluntary framework developed from existing standards, guidelines, and practices as well as with input from industry and government [52]. The framework provides a policy framework for organisations to assess and improve their ability to prevent, detect, and respond to cyber-attacks [53].

Although initially developed for critical infrastructure organisations, the framework has proven to be flexible and useful to other organisations [54]. By implementing the framework, organisations are better able to cost-effectively manage their cyber security risks, maximising their return on security investment [55]. Another notable benefit of NIST is that it provides a common language reducing confusion on the meaning of terms used in contracts and other agreements.

The components of the NIST CSF [116], [119] are summarised in TABLE 1 below.

TABLE 1 [53], [57] Nist CSF Functions and Categories

--

Table 1- [53], [57] Nist CSF Functions and Categories Download PDF		Contents Q T

NIST recognised that SMBs often do not have security experts at their disposal to interpret the cyber security framework and developed a simplified version of the NIST Cyber Security Framework specifically for SMBs which is published as the NIST Interagency Report 7621 (NISTIR 7621) [56].

NISTIR 7621 provides guidance to SMBs on how they can improve the security of information, including systems and networks, physical security, personnel security, contingency planning disaster recovery and operational security [56]. It prescribes actions that small businesses should take (Essential Practices) and adds ten highly recommended practices [58].

B. Other Frameworks

The Australian Signals Directorate (ASD) Essential Eight, International Standards Organisation (ISO) 27001/2 and the Payment Card Industry Data Security Standard (PCI DSS) are among other popular frameworks relevant for SMBs [28].

The ASD Essential Eight is an Australian framework which provides a baseline for organisations in order to protect themselves [59].

ISO 27001 is an international standard, providing specifications for a best-practice Information Security Management System (ISMS) [60]. ISO 27001 was developed to help organizations protect their information in a systematic and cost-effective way through the adoption of an ISMS [61]. The ISO 27001 standard groups the controls that organisations can select to tackle information security risks into 14 sets or domains [62]. ISO 27002 compliments ISO 27001 by providing more detailed guidance and a reference for selecting security controls within the process of implementing an ISMS [60].

The PCI DSS is the standard for the protection of cardholder data [45]. The PCI DSS controls framework helps SMBs to layer their defences around payment card data operations, improving their ability to maintain the confidentiality and integrity of customers’ payment card details, in turn safeguarding the company’s reputation. However, meeting PCI DSS compliance has been difficult for SMBs with only one in five managing to maintain their annual compliance obligations. Boese found that unlike larger corporations, small businesses lack the resources to become PCI DSS-compliant [45].

SMBs may struggle to meet their business objectives as well as compliance requirements when adopting a single framework, thus some researchers recommend to adopt a hybrid framework [55]. The Secure Controls Framework (SCF) was developed as a hybrid framework to cover NIST CSF, NIST 800–53 and ISO 27002 [63]. Fig. 2 shows the SCF and how some of the frameworks and standards overlap. Essentially the SCF can be seen as a superset covering NIST CSF, ISO 27001/2, PCI DSS and ASD Essential Eight.



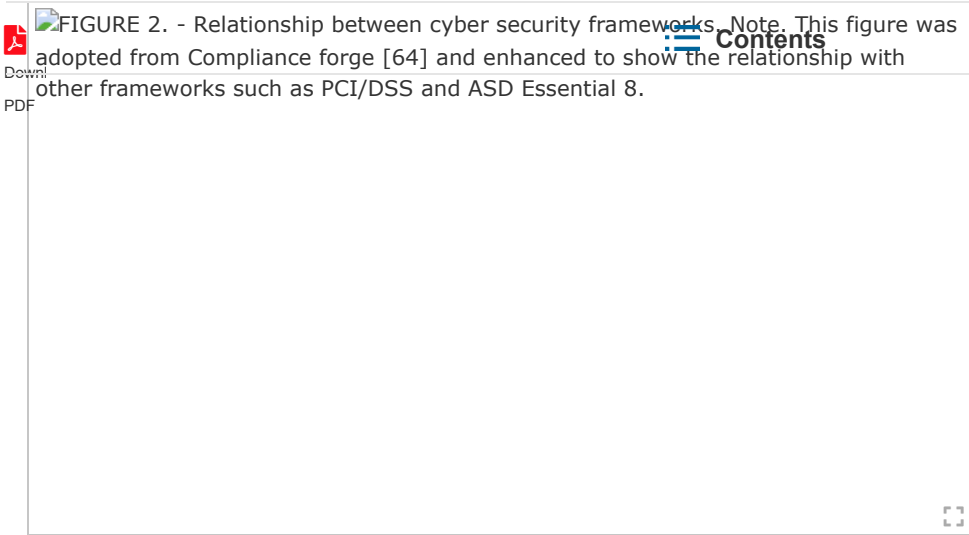


FIGURE 2. Relationship between cyber security frameworks. Note. This figure was adopted from Compliance forge [64] and enhanced to show the relationship with other frameworks such as PCI/DSS and ASD Essential 8.

SECTION IV.
Related Surveys

To the best of our knowledge, there exist only two surveys of a similar nature – one focussed on the UK [16] and one focussed on Australia [15].

Tam *et al.* discussed the research data challenges plaguing SMB cyber security researchers where the lack of publicly available data leads to little data being obtained largely from convenience sampling [15]. Self-reporting is also highlighted as an issue in SMB cyber research which causes awareness biases. They discuss challenges faced by SMBs as well as advantages or opportunities for SMBs. They also highlight the need for research data in businesses with less than 20 employees.

Alahmari and Duncan’s review of SMB cyber security research was aimed at revealing the role played by SMB management in addressing cybersecurity risks [16]. They analysed 15 articles and identified threats, behaviours, practices, awareness, and decision making as the perspectives that play a role in SMB cyber security risk management.

Our survey differentiates itself by analysing a much larger body of literature and aligning the surveyed literature to a well-known cyber security framework which previous surveys have not done. Our survey categorizes the literature using a taxonomy based on NIST CSF. Unlike the previous studies, we also investigate the geographic spread of the surveyed research.

SECTION V.
Paper Selection Criteria

The literature analysed in this study consists of 40 scholarly academic and peer-reviewed publications, dating back to 2005 (see TABLE 5, Appendix A). For the search we used the Murdoch University Online library which indexes and searches popular academic databases and repositories such as Scopus, Web of Science and many other original research databases such as IEEE Explore. Outside the Murdoch University online library, Google Scholar was also used to widen the search. We set the inclusion and search criteria are as follows:



- Clearly articulated methodology



 Table 2- Categorisation of Data Collection Methods

 Table 3- Percentages of Publication Types

Help

Table 4- Good Cyber Security Practices Contents	
Download PDF	

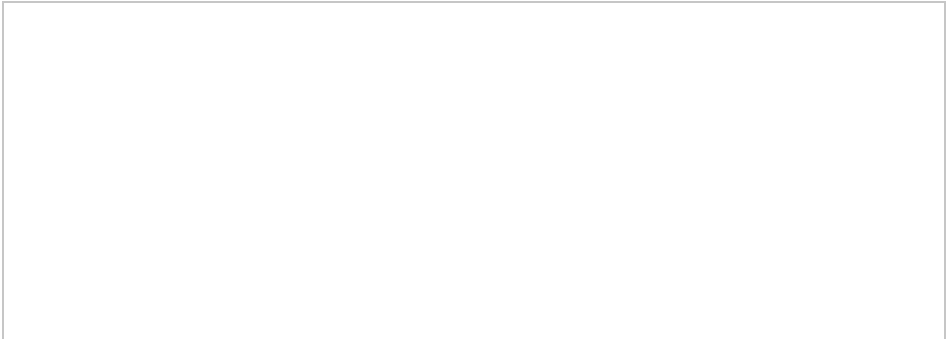
TABLE 5 Publications Included in Our Study

Table 5- Publications Included in Our Study

Each publication was categorised as journal paper, conference paper, doctoral dissertation or Master’s thesis.

A qualitative systematic review of literature was carried out, paying attention to the focus of the research questions and themes of the research. We adopted the qualitative systematic review approach due to the difficulty of performing meta-analysis of studies within a particular topic. Qualitative approaches have been developed to review and assess the quality of research findings, as well as identify patterns and relationships amongst studies on a particular topic [65], [66].

Publications were shortlisted for analysis and reviewed to determine the SMB cyber security topic or theme, the country where the research was conducted, the research methods used as well as the data collection methods. The resulting process followed is depicted in Fig. 3.



PDF

Help



FIGURE 3. Methodology visualised. This figure visually depicts the process followed in this research.

We developed the NIST CSF Research Classification Tool (NCRCT) shown in Fig. 4 to help us align each publication with the functions of NIST CSF. For each included publication, the research aims, objectives and questions were parsed through the tool to help determine the NIST CSF category (Table 1) it aligned with. Using this tool, we determined the corresponding NIST Category or categories.

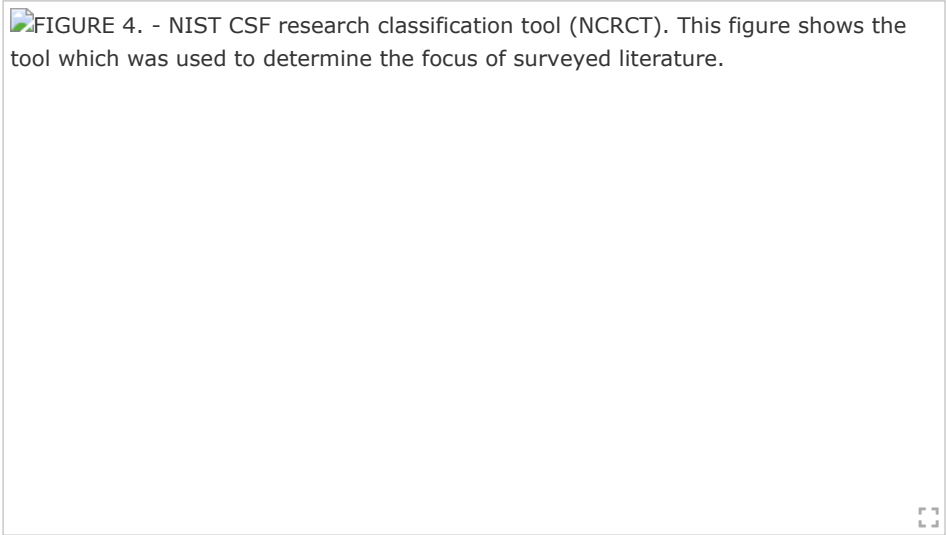


FIGURE 4. NIST CSF research classification tool (NCRCT). This figure shows the tool which was used to determine the focus of surveyed literature.

Furthermore, the research methodology and research design of each publication were reviewed to establish whether it was a qualitative, quantitative or mixed method approach and also to establish what data collection technique was used. The data collection methods are categorised as shown in Table 2.

Additionally, as each paper was analysed, the challenges faced by SMBs were noted and are discussed in Section VI.A Furthermore, we also identified recommended practices for SMBs suggested by the literature and discuss these in Section VII.

It should be noted that our literature search results are by no means exhaustive. Search results were limited to the repositories described above. Non-English research repositories could not be accessed and publications in other languages such as French, German, Chinese would have been precluded.

Download PDF

Contents

Q

T

SECTION VI.

SMB Cyber Security Research

Our work investigated the alignment of SMB research to the popular NIST CSF framework. It also investigated the methods, data gathering techniques and the geographic spread of past SMB cyber security research. In the process we also examined the common challenges faced by SMBs in implementing good cyber security. This section discusses the findings related to the research questions.

A. Cyber Security Challenges

Previous research identified several challenges that SMBs face in implementing sound cyber security. In a recent study, top challenges were found to be the lack of finances to pay for talent, issues with regulatory compliance as well as a shortage of professionally available talent [67]. Some researchers have categorised challenges faced by SMBs into technical, human, organisational, financial and legal challenges [15]. In the 2018 State of Cyber Security in SMBs study, the three main challenges faced by small businesses identified were: (i) not having the in-house expertise to mitigate cyber risk; (ii) IT budget constraints; and (iii) a general lack of understanding of how to protect against cyber-attacks [31].

Several other factors are suspected to also influence the poor cyber security posture of SMBs. Research by Deloitte [68] suggested that the age of the business owner or manager played a part in the security posture of their business, as well as their attitude and use of technology. The major factors influencing poor SMB cyber security posture are presented below.

1) Underestimating the Risk

Cyber risk transcends data breaches and privacy concerns. As Borenstein [69] alluded, the threats have evolved into more sophisticated schemes that prove very costly, disrupting entire businesses, industries, supply chains and even nations. Research has however shown that small business owners often have the tendency to underestimate cyber security risk [70], [71].

In Australia, almost half of the SMBs surveyed believed that they could protect their business from cybercrime by limiting their online presence. SMBs reported limiting their online presence to a business website, contact details and social media, with only 15% of survey respondents offering a business website with product viewing or purchasing functionality [43]. Notwithstanding the significant economic benefits of a greater presence online, the SMBs perception of cyber risk appears to be misguided. Cyber risks transcend websites and social media to include internet connected desktops, laptops, tablets, phones and nowadays internet connected devices and sensors (IoT) [19]. Any of these could expose the SMB to a cyberattack. Besides social media use, 55% of SMB owner-operators surveyed alluded to also using email to communicate, unknowingly exposing themselves to threats such as phishing and ransomware attacks [43]. They wrongly assumed limiting their online presence to be a safety measure preventing cybercrime, simultaneously unaware that email is the main vehicle for two thirds of malware related cyber security incidents globally [32].

A survey on small businesses in the US revealed the sector is more at risk than they think and is not taking necessary steps or investing in defending against cyberattacks [72]. Over half the businesses studied had not invested any measures to mitigate risks as they did not believe that they stored any valuable data, yet in fact they stored email addresses, phone numbers, postal addresses, home addresses, social security numbers and credit card details. This information which the SMBs perceived not to be of any value, is actually Personally Identifiable Information (PII), which forms the basis for most privacy regulation in Australia [73] and other countries. These findings demonstrate that there is an element of naivety in the operation of small businesses.

PDF

Help

Another example from the US is that only one in five businesses are reported to be able to meet their annual obligations under the PCI DSS standard. Some do not believe that they have any valuable data assets or business impacting IT systems; some do not see the business benefits or return on investment in complying and ignore their obligations [12].

Digital supply chains also introduce new cyber risks for business [33], [74], [75]. Although many businesses were found to perceive the risk other supply chain partners introduce to them, they do not perceive the risk they pose to their supply chain [47].

Bhattacharya [76] asserted that small businesses are always going to be primarily focused on sales and revenues in order to survive and stay in business. With this being their core focus, cyber security issues are likely neglected as they are not seen as valuable contributions to the core business.

2) Lack of Skills and Knowledge

Academia and industry researchers have suggested that small businesses remain exposed and susceptible to attacks because they do not know what to protect [25], [58], [77], [78], [79]. The work in [77] and [79] found that SMBs are struggling with the complex demands of carrying out risk assessments and the manner in which to adopt cyber security best practices into their organizations.

The Australian Small Business and Family Enterprise Ombudsman alluded that the lack of awareness regarding cyber security is one of the biggest threats facing small business operators [80]. The lack of cyber security awareness is evident not only among employees but also among managers who are the decision makers but found to be unaware of the technical solutions available to address their cyber security challenges [16]. SMBs were also found to lack knowledge in assessing the capabilities of their IT service providers [28]. A common challenge with SMBs in the financial card payment industry is a lack of awareness and knowledge on how to become compliant even with mandatory regulations such as PCI-DSS [45], [81]. Thus SMBs require help with creating policies and complying with regulations [15]. SMBs also struggle to implement crucial monitoring and security systems (such as a SIEM) due to their complexity and the requisite skills and knowledge not available to SMBs. This is not surprising given that research found a lack of appropriate education amongst the IT professionals working in SMBs [21].

These assertions were confirmed in a 2019 survey of small businesses, citing insufficient personnel, insufficient budget and a lack of understanding around how to protect against cyber-attacks, as the biggest challenges for SMBs when trying to improve their cyber security posture [46]. This situation does not seem to have changed as recent studies consistently rated these as the main challenges [10], [31], [46].

3) Lack of Resources

SMBs are less likely to employ dedicated IT staff, let alone cyber security specialists [74]. A medium or large company may have sustainable resources for dealing with cyber-attacks, whereas the relatively low income of a small business generally equates to fewer resources allocated toward cyber defence strategies. Fewer human and financial [36], [71], [82] resources [36], [71], [82] make it difficult for most SMBs to comply [83] even with regulations such as PCI-DSS [45]. SMBs also fail to adopt more advanced cyber security technologies such as effective technical controls using machine learning due to the high costs [84]. Some researchers found that achieving a good level of cyber security awareness was one of the biggest challenges for organisations today [25], [79]. The problem is only compounded for SMBs because they face the same challenge but with much fewer resources [25]. As a consequence, some SMBs trust their IT service providers to take care of their cyber security, but without the necessary contractual arrangements in place or clear definition of the responsibilities [85]. McLaurin recommended SMBs should align the little resources they have to the threats that they face [28]. Thus, SMBs require cyber security solutions that are affordable, easy to implement and use [86], [87]. Onwubiko and Lenaghan recommend that SMBs adopt security models that combine multiple security facets together thereby reducing costs of implementation and management [9]. The Centria Cyber Security Manager concept is an example of this approach where SMBs can share cyber security expert costs [8] thus making it affordable.

4) Rapid Pace of Technology Advancement

Berry and Berry [88] found that small business owners struggle with risk management approaches for mitigating cyber threats due to the rapid pace of advancement in technologies. Some authors even argue that cyber security risks are evolving faster than the rate of digital technologies evolutions [24]. Thus, the inexperience with security technologies contributes to SMBs challenges [23]. In a recent study of cyber security incidents and data breaches, the Ponemon Institute found that SMBs are ill prepared to deal with risks created by third parties and the Internet of Things (IoT) which is growing at an increasingly rapid pace [10].

5) Conflicting / Excessive Cyber Security Information

An Australian study in 2017 indicated that general awareness of cybercrime as a business risk was increasing amongst Australian SMBs, however many do not know where to get help from when responding to cybercrime events. They were found to be looking to multiple sources for help, ranging from Google searches to government and police [7]. Notably, 38% of respondents reported reaching out to an IT forensic consultant for help [43].

In a bid to improve the cyber awareness of SMBs, industry, government and other bodies make resources available, however as Renaud and Wier [7] found, the wealth of online information is at times conflicting, causing confusion and uncertainty amongst SMBs. It is possible the overwhelming availability of cyber security information hinders rather than helps SMEs. For example, in 2016 financial industry groups complained to NIST that banks are being burdened with a growing number of competing cyber security guidelines [89].

Another challenge with cyber security information or messaging is the negative connotations associated with the narrative of data breaches, regulatory fines and business disruption. Lloyd [47] suggests that business leaders need to reframe how they think about cyber security, with a focus on the opportunities that good cyber security presents rather than the consequences of its absence. For instance, effective cyber security allows companies to innovate, which drives revenue, profit and growth [15]. Good cyber security assists businesses to gain its customers' trust. Additionally, it gives businesses credibility in the supply chain, hence creating more opportunities [33], [74], [75].

6) Lack of Perseverance

SMBs do care about cyber security despite the limited implementation of known security precautions [4], however businesses that start off implementing a number of security measures may, over time, become lax, especially since there is no visible benefit that accrues from the extra effort and expense. They can also inhabit a sense of false security, having not kept up with the emerging risks.

Renaud [90] found small businesses are inconsistent in their implementation of security measures based on their appraisal of threats and the ability to implement risk controls. Key findings from a 2019 cyber security benchmark report also showed small businesses are challenged with cyber security initiatives to ensure a quick response to emerging cyber threats [91].

B. Focus of Cyber Security Research

Our results in Fig. 5 show that SMB cyber security research has largely been focussed on the Identify (27 out of 40) and Protect (23 out of 40) functions of the NIST CSF framework, with little work on the Detect (9), Respond (6) and Recover (5) functions. In the Identify function, governance, risk management strategy and risk assessment were the most popular topics which researchers (see Table 5, Appendix a). In the Protect function, most publications researched the cyber security awareness and training of SMBs with Information protection processes and procedures being the second most popular category. Overall, across all of the NIST CSF categories, awareness and training has been the most popular topic.

[Contents](#)

PDF

Help

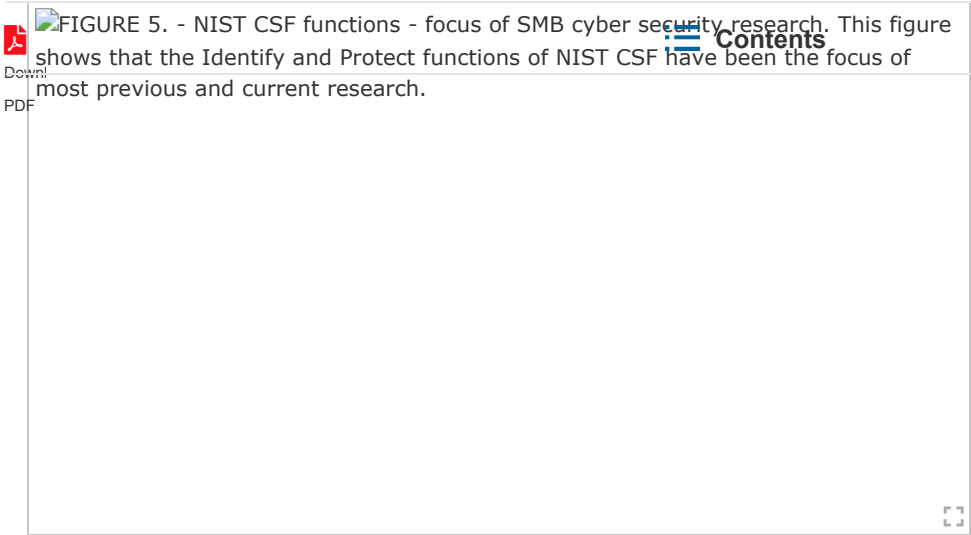


FIGURE 5. NIST CSF functions - focus of SMB cyber security research. This figure shows that the Identify and Protect functions of NIST CSF have been the focus of most previous and current research.

The following sub sections will discuss the literature in relation to its respective NIST function and categories.

1) Identify

The identify function of the NIST CSF is meant to ensure that businesses understand the business context, the resources that support critical functions, and the related cyber security risks so that they can prioritize efforts, consistent with its risk management strategy and business needs. Four of the six categories of the Identify function [55] were represented in the literature reviewed. The functions Asset Management and Business Environment were not represented in the literature.

Early SMB cyber security research explored the cyber threats to SMBs, vulnerabilities, risks and practices [9], [26], [34], [79], [92], [93], [94]. Whilst other authors were industry agnostic in their studies, Heikkila *et al.* targeted their study to SMBs in the manufacturing industry [8] which had unique challenges due to digitisation and the adoption of the Internet of Things (IoT). Valli [95] targeted lawyers who require education on how to use encryption and were failing to report cyberattacks to the government’s online reporting tool.

While most researchers focused on the challenges [25] faced by SMBs, others have found opportunities for SMBs when it comes to cyber security. Unlike large organisations, SMBs were found to have the advantage of being small, agile, and having flexible IT arrangements [15].

Some researchers studied risk management practices in SMBs whilst some explored strategies SMB use to prevent breaches, for example [96] and [97]. Several SMB cyber security researchers focused on the Governance category in the past decade. Aljumaili [98] explored information security policies and practices required by SMBs while Patterson [82] studied policy decisions in small businesses.

Researchers such as Burton-Howard [83] and others [45], [82], [87] focussed their research on governance and compliance including policies, legislation and compliance. Others concentrated on decision making related to cyber security amongst management in SMBs [82], [96]. Decision making approaches were found to depend on five perspectives which are cyber security threats, behaviours, practices, awareness and decision making in order to apply the correct remedies [16].

Additionally, the deficiency of existing laws was discussed with better laws to help protect SMBs being called for [83]. Tam *et al.* added that legal and policy work is needed to help SMBs become more cyber resilient [15]. Management is encouraged to ensure a good cyber security culture in their organisations [87].

PDF

Help

Three studies [33], [74], [75] touched on cyber security supply chain risks – an emerging topic in SMB cyber security. Sangani *et al.* [74] developed a security and privacy architecture to help SMBs adopting cloud services. Cloud providers are part of the supply chain for SMBs adopting cloud, however their security responsibilities have limitations with some responsibilities falling in the hands of the cloud customers. Thus, in addition to understanding cloud benefits, SMBs are also urged to be aware of their responsibilities under these arrangements.

Some researchers based their research on cyber security frameworks such as the NIST CSF [28], [99]. Some designed new frameworks [74] whilst some identified shortcomings [94], [100], [101] with existing frameworks and suggested modifications or enhancements to existing frameworks that SMBs could adopt. Examples include the SME Cyber Risk Assessment suggested by Armenia *et al.* [99] and another by Emer *et al.* [102]. Benz and Chatterjee proposed an SME Cyber Security Evaluation Tool (CET) based on the NIST CSF targeting SMBs. Beachboard *et al.* [79] proposed an open development approach to develop a decision heuristic based risk assessment which allows SMBs to quantify costs and estimate probabilities for specific threats in their risk assessments. Considering the difficulty of practically implementing cyber security in SMBs, Borges and Carias proposed a more holistic framework which provides an implementation order for SMBs to follow [18]. Bada and Nurse proposed a framework for education and awareness to support SMBs [25]. Coertze *et al.* [101] proposed enhancements to the Information Security Management Toolbox to help SMBs with creating automated security policies and monitoring compliance. There is however very little evidence on the practical implementation of most of the proposed toolsets and frameworks.

2) Protect

According to NIST [103], the Protect function “supports the ability to limit or contain the impact of a potential cyber security event”. Examples categories within this Function include Access Control (validating identities and access to different systems, facilities, etc.), Awareness and Training (giving employees and others the ability to be part of the cyber plan with education and training), Data Security (manage data according to company standards in order to mitigate cyber security risks, and protect its Availability, Integrity and Confidentiality proactively), Information Protection Processes & Procedures (putting in place the policies, processes, and procedures that are needed to manage protection of assets), Maintenance (continuously repairing information system components) and Protective Technology (deploying security solutions needed to protect assets in line with company policies).

Cyber security awareness has been a key focus of SMB cyber security research in early and recent years [35], [81], [92]. Several works analysed by us had training and awareness as their key focus with authors like Valli *et al.* specifically focusing on the cyber awareness of lawyers [95] and Milos studying the awareness levels of IT professionals in SMBs [21]. According to Fehér [75], it is most important to improve the user’s awareness. The argument is that SMBs should have a proper understanding of the threats their businesses face and how to mitigate them [74]. Cook [85] found that awareness in SMBs studied was broken into three themes which are: knowledge of third-party vendors, knowledge of protection and knowledge of strategic plans.

In general, training was found to raise the awareness and self-efficacy [81], [95]. Barosy identified making people aware of their responsibilities and roles in information technology as the critical factor in a cyber security awareness program for SMBs [97] and should be an ongoing exercise given the rapidly evolving threat landscape. Carnell [80] found that loss of sensitive data had a direct correlation with security awareness and knowledge of cyber security damage. Like large enterprises, SMBs struggle to educate and train their workforce except for SMBs the problem is worse due to a lack of resources [25]. However, cyber awareness and training is essential to keeping businesses cyber secure and Carias [18] suggested that every domain of a cyber security framework should be supported by training and awareness. Bada and Nurse [25] proposed a cyber awareness programme for SMBs with key areas of the programme being the initial engagement with SMEs, improving security practices and culture, programme and trusted third-party resources / services – all underpinned by a communication strategy.

Cyber security awareness levels of IT professionals in SMBs was found to be low due to a lack of appropriate education and conflicting priorities since they are not dedicated to cyber security tasks [21]. Lawyers in Western Australia were found to need education particularly on the use of encryption to help protect data in transit or at rest given their professional privilege and access to sensitive client data. [95].

PDF
Download
Policies and procedures are seen as one of the ways SMBs can solve the challenge aligning their information systems and resources with requirements of security standards [90]. Several publications in our study were devoted to policies that SMBs could implement to ensure good cyber security behaviours in their organisation [96], [98]. McLaurin identified that SMB owners required assistance with writing cyber security policies [28] as research has shown that a lack of human and financial resources was a barrier to drafting, implementing, and complying with sound information security policies [101].

Most recently researchers have studied protective cyber security technologies in SMBs such as machine learning [84], [100] which are seen to be effective in protecting against cyber-attacks. Mercl and Horalek [104] examined the practical implementation of a Security Incident Event Monitoring (SIEM) in an SMB environment [104] with their results showing that SIEM implementation in SMB environments was both costly and complicated especially considering SMBs may not have the requisite knowledge and skills.

The challenges SMBs face when implementing cyber security is another popular theme [36], [71]. Deficiencies in SMB cyber security was a focal point of several studies. Examples such as the failure to implement firewalls on devices despite them being built into operating systems were attributed to the lack of knowledge and awareness [35]. The majority of SMBs were also found to not install anti-malware on mobile devices. SMBs were also found to be deficient in performing risk assessments in their environments [79].

3) Detect

According to NIST [103] the Detect function helps ensure organisations develop and implement appropriate activities to identify the occurrence of a cyber security event.

The Detect function enables timely discovery of cyber security events. Examples of categories within this function include: Anomalies and Events (ensuring anomalies and events are detected, and their potential impact is understood), Security Continuous Monitoring (implementing security continuous monitoring capabilities to monitor cyber security events and verify the effectiveness of protective measures including network and physical activities), and Detection Processes (maintaining detection processes to provide awareness of anomalous events) [103].

Only six of the papers in our review had the Detect function as their focus [8], [18], [84], [86], [94], [104]. As shown in Table 5, four of them fell into the Security Continuous Monitoring category whilst the remaining two fell into the Detection Process category. The Anomalies and Events category was not represented.

Whilst virus and malware protection were found to create net benefits and encourage a positive user experience in SMBs [86], Heikkilä *et al.* [8] argued that successful security management hinges on continuous monitoring and SMBs require easy to deploy security services offering such. They explored the Centria security laboratory as a low-cost solution for SMBs in the manufacturing industry to manage their cyber security including continuous security monitoring. Continuous monitoring of an IT environment is achieved using a SIEM which researchers Mercl and Horalek focused their study on [104]. They studied two SMBs implementing the IBM Security QRadar SIEM and found that such implementations required guidance and assistance from knowledgeable professionals due to the complexity of the implementation. The implementation of a SIEM in the SMBs was found to hinge on the following factors: the number of company employees; geological division of IT infrastructure; financial aspects and limitations of the company; the number and type of devices that are managed by the system and the audit reporting requirements.

Rawindaran *et al.* [84] investigated the challenges SMBs face in adopting Machine Learning Cyber Security (MLCS). Their study revealed that although MLCS has been successfully applied in many monitoring applications, for example in network intrusion detection systems (NIDS), there was still poor adoption of MLCS techniques among UK SMBs.

Kaila and Nyman [94] stressed the importance of monitoring as it not only allows SMBs to uncover what happened in the event of a breach, but also helps them make informed responses to incidents. Carias *et al.* [18] focussed their study on the best implementation order for a cyber resilience framework in SMBs. They found that different experts have differing priorities, however a general consensus reached indicated that detection processes and continuous monitoring should be

implemented together with information security techniques after implementing governance, risk management, asset management, vulnerability management and business continuity.

4) Respond

The Respond function involves activities that ensure organisations develop and implement appropriate activities to take action regarding a detected cyber security incident [103]. According to NIST, “the Respond function supports the ability to contain the impact of a potential cyber security incident”. Examples of categories within this function include Response Planning (ensuring response planning process are executed during and after an incident), Communications (managing communications during and after an event with stakeholders, law enforcement, external stakeholders as appropriate), Analysis (analysis is conducted to ensure effective response and support recovery activities including forensic analysis, and determining the impact of incidents), Mitigation (mitigation activities are performed to prevent expansion of an event and to resolve the incident) and Improvements (the organization implements improvements by incorporating lessons learned from current and previous detection / response activities). The Respond function activities such as response planning, impact analysis and improvement from lessons learnt go a long way in ensuring cyber resilience in SMBs however in their study, Powell *et al.* [34] found that almost half of SMBs either did not have an emergency action plan or did not have it written and fully implemented. Given the threat landscape is ever evolving, traditional methods of protecting against known threats we seen not to be effective enough, thus Carias *et al.* [18] claimed that cyber resilience is a more holistic approach to cyber security which assists SMBs to anticipate, detect, withstand, recover and evolve after cyber incidents.

Seven out of 40 publications in our review were focused on the Respond function of the NIST CSF. The Mitigation category was the most popular category in this function accounting for over half of the papers. Analysis and Improvements were also represented; however, Response Planning and Communications were not.

Regarding Mitigation, Kaila and Nyman [94] identified logs as crucial in the event of a compromised system as they help uncover what happened and help inform SMBs on deciding on how to respond to incidents. Having good mitigation strategies also brings a business benefit where the organisation can demonstrate compliance and reasonable effort to protect the business, customer or staff data should a cyber incident occur [18]. Alharbi *et al.* [105] measured how certain cyber security practices can affect the level of harm caused by cyber-attacks and found that having a cyber security inspection team and recovery plan reduced the financial damage caused by cyberattacks in SMBs. For incidents that eventuate, SMBs were disinterested in reporting the incident or conducting forensic analysis due to the costs of the activities; SMBs simply wanted to move on rather than spend time determining the source or cause of attack [106]. Machine learning (ML) techniques and artificial intelligence (AI) were found to be very effective in the detection of anomalies and enhancing the functionality of modern network/host intrusion detection and prevention systems, however Rawindaran *et al.* [84] found that some SMBs were not aware or had disregarded that AI and ML were built into the cyber security solutions they invested in. Rawindaran recommended that awareness of AI and ML in cyber security should be improved amongst SMBs.

5) Recover

The recover function of the NIST CSF guides SMBs to put in place measures to ensure that they can recover normal operations after a cyber security incident [103]. Recommended activities under this function are designed to enable any business functions and capabilities affected by a cyber-attack to be able to be restored after the incident. This ability to recover from or adjust easily to misfortune or change part of cyber resilience [107]. For SMBs, not only should they be able to defend against cyberattacks, but they need to be able to return to normal operations after an incident. Categories under this function include Recovery Planning (recovery processes and procedures are executed and maintained to ensure restoration of systems or assets affected by cyber security incidents), Improvements (continuous improvements from lessons learnt and communications to ensure the organisation is well coordinated during cyber incidents [103]) and Communications (restoration activities are coordinated with internal and external parties) [103].

Only five [15], [18], [85], [94], [105] of the papers reviewed focussed on the Recover function with the Recovery Planning category being the most popular category. The Improvements category was not represented in the literature. Tam *et al.* highlighted the lack of research in cyber resilience which our study also validates. They noted that cyber security insurance was a challenge for SMBs



PDF

Help

given it is a new concept [15]. They added that highly expensive remediation costs of cyber incidents make it particularly difficult for SMBs to recover, hence cyber insurance would be the best approach; however, it is not well understood amongst SMBs. SMBs were also found to have a reliance on third party vendors for their infrastructure and security preventative measures [85], however this does not necessarily mean the third party takes ownership of the SMB's recovery planning. Cook's study [85] also revealed that SMBs were adopting preventative and protective strategies, however our analysis of Cook's results revealed that planning for the worst was not quite evident amongst the SMBs studied. Planning for the worst is crucial for recovery in the event that a cyber-attack occurs and this can be achieved by having a business continuity plan in place [94]. In their research Alharbi *et al.* [105] found that having an inspection team and a recovery plan reduced the financial damage a cyber-attack had on SMBs in Saudi Arabia. Additionally, their research revealed having contact with cyber security authorities statistically reduced the restoration time following a cyber-attack. They recommended that SMBs should focus more on certain cyber security practices that can decrease the impacts of cyber security attacks. Carias *et al.* [18] claimed that cyber resilience was a more holistic approach which SMBs should adopt and they proposed a framework to make it easier for SMBs to implement cyber resilience practices. However, there is no data on the practical application of this framework.

C. Research Areas Requiring More Work

Several categories from the Detect, Respond and Recover functions were underrepresented whilst some categories were not represented at all. Underrepresented categories include Detection Process, Security Continuous Monitoring, Analysis, Improvements, Mitigation, Communications and Recovery Planning. Categories with no representation at all include Maintenance, Anomalies and Events, Response Planning, Communications, and Improvements.

It is quite evident from the results above that there is limited research on cyber resilience. Previous researchers have also found that in practice many organisations narrowly focus on technology defences and prevention of cyber risk but neglect other cyber resilience building activities like risk transfer and response planning aspects which are covered by the Respond and Recover functions of the NIST CSF [24]. Our results indicate that, overall, little research attention has been given to the Detect, Respond and Recover functions of the NIST CSF all of which are part of developing cyber resilience. In 2020, IBM Security reported that incident response preparedness was the highest cost saver for businesses when it came to data breaches, saving businesses on average of USD\$ 2 million in the event of a data breach [30]. This highlights the importance of the Respond and Recover functions to businesses.

We believe that the narrow focus of SMB cyber security research is largely attributed to the limited quantity of research in the area, since most of the research to date has focused on large enterprises. Our study highlights the need for additional research in more categories.

D. Geographic Spread and Publication Types

When considering the countries in which SMB-related cyber security research is conducted/published, the USA had the highest number of papers overall, accounting for 43% of publications analysed (Fig. 6). Together with other countries, Australia was found to be underrepresented in the SMB cyber security research literature, particularly in the academic literature of master's theses and doctoral dissertations. Outside the USA and Australia, the majority of the relevant research is conducted in Europe. Africa, Asia, the Middle East and South America are underrepresented with little to no publications on SMB cyber security. We suspect the lack of literature from Asia and South America may be due to non-English publications not accessible to us.

[Contents](#)

PDF

Help



FIGURE 6. Total publications by country. This figure shows the geographic spread of literature surveyed in this study.

Table 3 shows that journal papers were the most popular type of publication accounting for 47.5% of the literature reviewed. They were followed in popularity by conference papers (20%) and doctoral dissertations (17.5%) and lastly master’s thesis at 15%. Between 2005 and 2013, there were few publications examining SMB cyber security with an average of one publication each year. Between 2013 and 2014 there was an increase in the number of doctoral dissertations and master theses focused on the topic.

It is encouraging that the number of publications on the topic has increased in recent years. Fig. 7 shows a general upward trend indicating a growing interest in the topic among researchers.

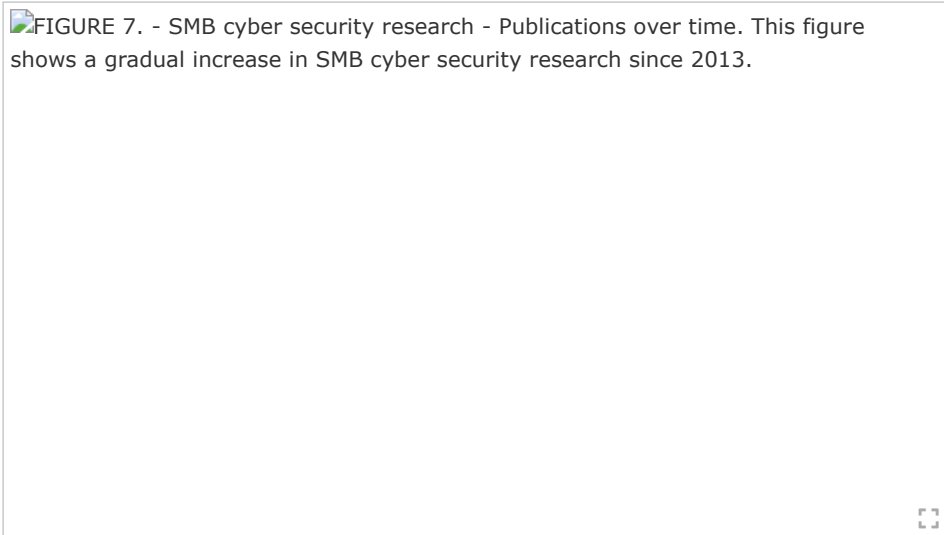


FIGURE 7. SMB cyber security research - Publications over time. This figure shows a gradual increase in SMB cyber security research since 2013.

E. Research Methodology Used

As shown in Fig. 8, we found that SMB cyber security researchers have been predominantly using qualitative methods (70%) as opposed to quantitative (25%) and mixed methods (5%). These findings are consistent with previous research which found that a large proportion of cyber security research is focussed on risk with most researchers using qualitative methods to assess cyber risk [108]. Information security is viewed as being too complex to model with quantitative methods but authors like Douglas and Seiersen [109] strongly advocate for evidence-based research methods in

cyber security, as opposed to testimonial-based methods of identifying cyber security best practices and effectiveness of controls. They emphasise the role of cyber experts in computing cyber security metrics to ensure a factual and unbiased outcome. In 2019, 30% of organisations reported using quantitative methods to express cyber risk exposures, up from 17% in the previous two years. Marsh recommends that organisations should quantify cyber security risks to drive better informed investment, and performance measurements thus treating cyber security risks in the same economic terms as other enterprise risks [24].

FIGURE 8. - Research methodology used by SMB cyber security researchers. Most researchers are using qualitative methods to research cyber security in SMBs.

Very few SMB cyber security researchers seem to use mixed methods [25], [84]. Rawindaran *et al.* researched cyber security technology using mixed methods to study the adoption of machine learning cyber security in SMBs. Although most researchers adopted qualitative approaches in their studies [8], [9], [15], [16], [18], [21], [26], [33], [45], [74], [79], [83], [93], [94], [97], [98], [101], [102], [104], [106], some adopted quantitative approaches [28], [34], [35], [71], [81], [82], [86], [95], [99], [100]. For example McLauren adopted a quantitative approach to study to which extent SMBs should implement a security framework to offer the most return on investment [28]. Alharbi *et al.* [105] also adopted quantitative methods to measure the impact that SMB cyber security practices have on cyber-attack damage. Their research indicated that having an inspection team and a recovery plan reduced the financial damage that a cyber-attack had on SMBs in Saudi Arabia.

F. Data Collection Methods Used

The data collection methods (Table 2) used by researchers were analysed and our results in Fig. 9 show that literature reviews were the most common method for data collection used by researchers (43%), followed by surveys (25%) and interviews (17%). A combination of methods was used for 7% of the research analysed with the methods least used being questionnaires (5%) and experiments (3%). It is interesting to note that none of the publications analysed used observation as a data gathering method. We believe this is due to the complexity of observing user interactions with computer systems and user behaviour profiling which requires capturing large amounts of data, in a process that can be intrusive [110]. With emergence of automated tools, this may however be more feasible in the future [111].



FIGURE 9. Data collection methods used by researchers. The figure shows the findings that literature reviews are the leading method for data collection by SMB cyber security researchers.

SECTION VII.
Discussion and Recommendations

Many researchers of SMB cyber security use literature reviews for data collection whilst using largely qualitative methods. This indicates that there is limited original research in the field, such as case studies, surveys and experiments (all which can employ different data collection techniques including questionnaires, interviews, content analysis, observations [112]). While original field research is difficult in this highly sensitive area, it would be highly desirable to better understand the issues and provide better solutions. A literature-review-based approach also presents a challenge to researchers when there is limited literature particularly in localised contexts such as in Australia.

Whilst qualitative methods are quick and cost-effective in prioritising cyber risks, Alahmari noted the need for empirical research on topics like cyber security risk management in SMBs [16]. Well-established and powerful quantitative methods can be used [113], however authors such as Edgar and Manz argue that the unavailability of objective data limits their applicability and credibility [114], [115]. Apart from a lack of data, the limited use of quantitative methods may also indicate a lack of maturity of research as quantitative methods are typically used to answer clear, predefined questions in the advanced stages of a study [116].

Despite the increase in SMB cyber security-related publications over recent years, several authors have suggested that more research is needed to understand the approaches to risk management SMBs undertake alongside their responses to cyber security threats. Such research will help highlight SMB cyber security activities for preparedness, the decision makers' perceptions of risk and approaches to improve their cyber security postures [70], [88].

Cyber-attacks are now moving beyond data breaches and privacy concerns to more sophisticated schemes, such as ransomware, that prove very costly, disrupting entire businesses, industries, supply chains and even nations. Some researchers such as Baskerville *et al.* have recommended strategies to ensure a balanced approach to the prevention and response paradigms of security [117]. However, many organisations narrowly focus on technology defences and prevention of cyber risk but neglect other cyber resilience building activities like assessments, risk transfer, response planning and training [24].

PDF

Help

Very few papers analysed in this study touched on aspects of SMB cyber security related to the security incident management and business continuity management categories of the NIST CSF. Since the threats will always be there, whether external or internal, cyber security risks cannot be eliminated, but a business can mitigate, manage, and recover from cyber-attacks [69]. SMBs should not only be able to defend against cyber-attacks in the first instance but also to return to normal operations after an incident. Eilts [118] found that small businesses that were able to improve their cyber security posture were those that had committed to incorporating cyber security preparedness activities into their routine business.

Although suggested priorities may differ, there is consensus in the literature on what is good cyber security. Bryan [61] points out that a reliable and affordable starting point to good cyber security for SMBs is a comprehensive information security system which contains a computer-use policy, information security training and business virus and malware protection [86]. Kaila and Urpo [94] suggest the useful first steps for start-ups and SMBs should be: identifying assets and risks; protecting accounts, systems, clouds, and data; implementing a continuity plan; and monitoring and reviewing. Other researchers suggested SMBs should put more focus on practices that can decrease the impact of cyber-attacks such as investing in an inspection team and a documented recovery plan [105]. It is not only the SMB's responsibility, but also technology vendors who have been challenged to incorporate security into computing technologies to assist the likes of SMBs with limited knowledge and access to expertise [26]. There are security responsibilities for both vendor and SMB customer, for example for cloud-based Software-as-a-Service (SaaS).

Table 4 below sums up the practices that are recommended by researchers [15], [21], [24], [25], [28], [30], [33], [34], [35], [36], [47], [59], [75], [81], [86], [94], [96], [119], [120], [121], [122]. Practical implementation of these practices is somewhat difficult for SMBs, which is why authors like Carias and Borges proposed a framework for the implementation order of these practices [18].

SECTION VIII.

Conclusion

Continuous on-going research is required to support the development of cyber security solutions for SMBs [15], [102]. Research in cyber security is however rarely focussed on SMBs, despite them representing a large proportion of business. SMBs contribute immensely to the global economy, and in particular in Australia they make up 98% of all businesses contributing one third of the GDP. Despite their large number and importance, our study shows that research in SMB cyber security is rather limited and narrowly focussed. This is consistent with previous findings of other researchers [15].

We also found SMB cyber security research to be concentrated in the USA despite other nations having similar high proportions of SMBs and facing similar threats but in different environments. This is in part due to our study only including English publications, but it may also indicate that not enough attention is being paid to SMB cyber security in many countries, despite SMBs representing the backbone of the nations and the global economy.

Our results show that significant attention and effort has been made towards research around security strategies and policies for SMBs, however there appears to be only limited work in the areas of practical implementation, detection, response and recovery.

Researchers have recommended that a deeper analysis of how SMBs implement security controls is required [28]. Our study found a lack of quantitative data in SMB cyber security research. In future work researchers should adopt more powerful well-established quantitative research approaches to investigate SMB cyber security.

When considering the popular NIST CSF, our study found that research related to the cyber security of SMBs is focussed on aspects of information security policies and operational security. Topics relating to cyber security incident detection, response and recovery are hardly accounted for in past



Download
PDF



PDF

Help

and current research. In Australia, 62% of small businesses have been a victim of a cyber-attack [11]. Given that past research has been mainly directed towards the prevention paradigms, researchers need to focus their work more on cyber resilience in order to ensure a more balanced approach to cyber prevention, response and recovery. Globally, governments should invest in incentivising research and initiatives to promote the resilience of SMBs. Cyber-attacks are inevitable, but when they do happen, SMBs should be able to respond and recover.

There is a need for governments and academic institutions to incentivise researchers to conduct more studies into SMB cyber security. The findings of our work can be used as guidance for researchers, academic and research institutions, governments and policy makers when selecting the focus of SMB cyber security research.

Appendix A

Table 5 lists the papers included in our study sorted by year of publication. It also shows the country of publication, methodology, data collection method used, as well as the NIST category that it fell under when analysed with our NCRCT tool.

Authors	▼
Figures	▼
References	▼
Citations	▼
Keywords	▼
Metrics	▼

ALSO ON IEEE XPLORE

Periodicity Detection of the Substitution ...

9 months ago · 1 comment

This paper presents a technique for investigating the cyclic properties of ...

False-Bottom Encryption: ...

10 months ago · 1 comment

We show how to implement a deniable encryption method from secret ...

Strategies to Measure Soil Moisture Using ...

a year ago · 1 comment

This review provides a detailed synthesis of various in-situ, remote sensing, ...

RadioPathomics: Multimodal Learning ...

a year ago · 1 comment

Current practice in cancer treatment collects multimodal data, such as ...

A Multi-Modal Deep Transfer Learning ...

6 months ago · 1 comment

Software-defined networking (SDN) has been recognized for its potent

PDF

Help

0 Comments



Download

PDF



Contents



Pawan Shah ▾

P

Start the discussion...



T



Share

Best

Newest

Oldest

Be the first to comment.

[Subscribe](#)[Privacy](#)[Do Not Sell My Data](#)[Back to Results](#)

More Like This

The Economics of Privacy-Privacy: People, Policy and Technology
2008 International Conference on Information Security and Assurance (isa 2008)
Published: 2008

Complementary Perspectives on Privacy and Security: Economics
IEEE Security & Privacy
Published: 2013

PDF
Show More
Help



Download

PDF

Contents



IEEE Personal Account

CHANGE
USERNAME/PASSWORD

Purchase Details

PAYMENT OPTIONS
VIEW PURCHASED
DOCUMENTS

Profile Information

COMMUNICATIONS
PREFERENCES

PROFESSION AND
EDUCATION

TECHNICAL INTERESTS

Need Help?

US & CANADA: +1 800
678 4333

WORLDWIDE: +1 732
981 0060

CONTACT & SUPPORT

Follow



[About IEEE Xplore](#) | [Contact Us](#) | [Help](#) | [Accessibility](#) | [Terms of Use](#) | [Nondiscrimination Policy](#) | [IEEE Ethics Reporting](#) | [Sitemap](#) | [IEEE Privacy Policy](#)

A not-for-profit organization, IEEE is the world's largest technical professional organization dedicated to advancing technology for the benefit of humanity.

© Copyright 2024 IEEE - All rights reserved.

IEEE Account

- » Change Username/Password
- » Update Address

Purchase Details

- » Payment Options
- » Order History
- » View Purchased Documents

Profile Information

- » Communications Preferences
- » Profession and Education

PDF

Help

» Technical Interests

Need Help?

Download PDF

» US & Canada: +1 800 678 4333

» Worldwide: +1 732 981 0060

» Contact & Support

Contents

Q

T

[About IEEE Xplore](#) | [Contact Us](#) | [Help](#) | [Accessibility](#) | [Terms of Use](#) | [Nondiscrimination Policy](#) | [Sitemap](#) | [Privacy & Opting Out of Cookies](#)

A not-for-profit organization, IEEE is the world's largest technical professional organization dedicated to advancing technology for the benefit of humanity.
© Copyright 2024 IEEE - All rights reserved. Use of this web site signifies your agreement to the terms and conditions.

PDF

Help